Clase 17 · Desarrollo de políticas, modelos de seguridad y planes de contingencia

Seguridad Informática Básica · Dra. Cintia Quezada Reyes · martes 3 nov 2026 · Tema 4 · Apuntes y resumen de estudio

PARTE 1 · Apuntes completos

Fases para desarrollar y documentar políticas, modelos de seguridad (abstractos y concretos, control de acceso, flujo de información e integridad) y fundamentos de los planes de contingencia. Continúa la Clase 16.

Fuente

NotebookLM (audio SIB-Clase17.m4a). Lo que no se pudo contrastar con el audio se marca como dudoso.

1. Fases para desarrollar y documentar políticas

- **Planteamiento de objetivos:** se parte de los objetivos específicos de la organización o del área.
- **Preparación:** definir quiénes forman el grupo de trabajo, la modalidad (presencial, virtual o juntas) y que cada integrante llegue con propuestas previas.
- **Redacción:** la junta no es para escribir desde cero, sino para revisar si las propuestas se alinean con los objetivos.
- **Edición y apoyo editorial:** formato oficial (portal, tipografía, márgenes, interlineado, colores) y revisión de ortografía y redacción; el documento regresa con observaciones cuantas veces haga falta.
- **Aprobación:** el creador no puede autoaprobar; pasa por una o varias comisiones (técnica, académica de cómputo, de reglamentos) y se valida con leyenda oficial, sello con fecha, firma o código QR.
- **Difusión:** entrega física con firma de recibido, distribución digital, liga en el contrato laboral, pósters en áreas clave o minicuestionario con calificación mínima (por ejemplo 8, con intentos).
- **Aplicación y revisión periódica:** entra en vigor con control de versiones (v01, v02…) y se audita ante cambios relevantes.

Examen

Las fases van en este orden: objetivos, preparación, redacción, edición, aprobación, difusión, aplicación y revisión periódica.

Componentes del documento final

- Ámbito de aplicación (áreas, proyectos o servicios, apoyado en organigramas).
- Análisis de riesgos: qué, de qué y cómo proteger.
- Catálogo de sanciones y estímulos, alineado a la Constitución y a las leyes.

- Usos éticos y preguntas frecuentes (FAQ).
- Procedimientos ante emergencias o incidentes.
- Glosario (contraseñas, passwords, siglas como PSC).
- Anexos (tablas de sanciones o diagramas largos).

Error común: llegar a redactar desde cero, que quien redacta sea quien aprueba, o reescribir protocolos de emergencia que la institución ya tiene (sismo, incendio): solo se referencian.

2. Modelos de seguridad: abstractos y concretos

- **Modelo de seguridad:** representación formal de sujetos, recursos, operaciones y reglas que determinan los comportamientos autorizados y garantizan que se cumplan las políticas.
- **Abstracto:** conceptual o matemático, sin detalles de implementación; habla de «Sujeto A», «Objeto X», «Actividad 1».
- **Concreto:** instancia que aplica las reglas con nombres y activos reales: «Juan tiene permiso de crear la base de datos».
- La profesora lo resumió así: el concreto «te pone nombres y apellidos».

Analogía: el plano abstracto dice que hay una puerta con cerrojo; el concreto dice qué puerta, en qué calle y quién tiene la llave.

3. Modelos de control de acceso

Modelo	Idea clave
Matriz de acceso	Filas = sujetos, columnas = objetos, celdas = derechos (usar, limpiar, desarmar, vacío = denegado)
HRU (Harrison, Ruzzo, Ullman)	Extiende la matriz con rigor formal: los derechos cambian con el tiempo y con condiciones («Lis usa la PC si está en su horario y trabaja en la organización»)
Take-Grant	Grafo dirigido (nodos = sujetos/objetos, aristas = derechos). **Take:** tomar derechos de otro nodo. **Grant:** conceder derechos propios a un nodo de menor jerarquía
Bell-LaPadula	Multinivel, solo **confidencialidad**: niveles no clasificado, confidencial, secreto, ultrasecreto; nadie de un nivel inferior ve información de uno superior

- Ejemplo de Take: el jefe de división toma la atribución de asentar calificaciones si el profesor no está. Ejemplo de Grant: el jefe delega en su secretaria enviar un correo institucional a su nombre.

Error común: creer que un permiso en la matriz es eterno e incondicional; HRU lo resuelve con condiciones de estado y tiempo.

4. Modelos de flujo de información

- Se basan en la teoría de la información y regulan los canales entre emisores y receptores para evitar fugas o deducciones no autorizadas.
- **Entropía:** grado de incertidumbre. A mayor incertidumbre, menos información útil para el atacante; a menor, más fácil el ataque.
- Ejercicio en el pizarrón (como el ahorcado): con «cuestionario» casi completo la deducción es inmediata; con una palabra que solo termina en «a» los alumnos dijeron salsa, araña, abeja,

pizza, regla, y la profesora había pensado «torta».
- Consecuencia para las políticas: prohibir pegar contraseñas en el monitor o usar usuario = contraseña (ej. Rodrigo/Rodrigo), por *shoulder surfing* (Clase 13).

Error común: dar mensajes de error o pistas que reducen la entropía para el atacante.

5. Modelos de integridad

- **Biba:** solo integridad; el sujeto modifica únicamente activos de **su mismo nivel** de integridad (ni inferiores ni superiores), para que datos poco fiables no contaminen los fiables.
- **Clark-Wilson:** no depende solo de niveles. Dos pilares: **transacciones bien formadas** (se manipulan los datos solo con programas autorizados que mantienen la consistencia) y **separación de funciones**. Combina integridad con confidencialidad y exige credenciales y permisos por actividad.

Error común: creer que estar en el mismo nivel da derecho a ver o editar toda la información.

6. Planes de contingencia

- **Plan de contingencia:** procedimientos planificados y documentados para recuperarse de un desastre, eventualidad o ataque y mantener la continuidad de la operación.

Las 4 fases

- **Evaluación:** diagnosticar, inventariar recursos, revisar si los planes previos están obsoletos.
- **Planeación:** acciones con base en un análisis de riesgos; responsables por área.
- **Ejecución:** poner el plan en práctica cuando ocurre la eventualidad.
- **Pruebas de viabilidad:** simulacros e inspecciones para ver si el plan sirve o hay que replantearlo.

Tipos de procedimientos

Tipo	Qué es	Ejemplo
Preventivo	Evita que ocurra la eventualidad	Revisar que el extintor esté cargado y no caduco; capacitar en primeros auxilios
Correctivo planificado	Se ejecuta ya ocurrida la eventualidad, con protocolo practicado	Usar el extintor adecuado; levantar reporte con día, hora y resguardo del equipo
Correctivo no planificado	Reacción instintiva por pánico	Correr, empujar o paralizarse en la puerta en un sismo

Error común: mezclar sismos, incendios y hackeos en un solo documento; deben ir por separado.

Contexto — no examen

- Ciberataque a refrigeradores en Francia y Finlandia: subieron la temperatura de forma remota y se echó a perder la comida.
- Colegio Rébsamen, como falla de las pruebas de viabilidad.
- Conducta de la gente en el sismo del 19 de septiembre de 2017 (personas congeladas en los marcos de las puertas).
- La alerta sísmica y por qué su tono es perturbador.

- Fuga de información en la sobremesa familiar por no firmar convenios de confidencialidad.

Pendiente

- El proyecto del curso se publicó (o se estaba publicando ese día) a los representantes de equipo en la plataforma; hay que leerlo y llevar dudas.
- Próxima clase: ventajas y desventajas de los planes de contingencia.

PARTE 2 · Resumen para estudiar

Versión corta de lo que más probablemente se pregunta. Léela primero y vuelve a la Parte 1 si algo no queda claro.

Tema	Idea para recordar
Fases de una política	Objetivos, preparación, redacción, edición, aprobación, difusión, aplicación, revisión
Quién aprueba	Nunca quien redacta: comisiones y sello, firma o QR
Modelo abstracto vs concreto	Genérico (Sujeto A) vs con nombres y apellidos
Matriz de acceso / HRU	Sujetos × objetos / con condiciones y cambios en el tiempo
Take-Grant	Take = tomar; Grant = conceder (grafos)
Bell-LaPadula	Confidencialidad multinivel
Entropía	Más incertidumbre = menos información para el atacante
Biba	Integridad: solo modifica su mismo nivel
Clark-Wilson	Transacciones bien formadas + separación de funciones
Plan de contingencia	Evaluación, Planeación, Ejecución, Pruebas de viabilidad
Procedimientos	Preventivo, correctivo planificado, correctivo no planificado

Hilo conductor

Una política se desarrolla por fases y se aprueba por alguien distinto de quien la escribe; los modelos de seguridad traducen esas políticas a reglas (acceso, flujo, integridad); y el plan de contingencia prepara cómo recuperarse si algo falla.